Authentication & Role-Based Access Control (RBAC)

Course: DBMS Mini Project (UE24CS395) • **Institution:** PES University (2026–2027)
Team: Saatvik Gupta (PES1UG24CS395) & Satyam Goyal (PES1UG24CS424)

1. Dual-Layer RBAC Architecture

Access control is strictly enforced at two independent architectural levels:
1. **Application Gateway (FastAPI + JWT):** Endpoints authenticate bearer tokens and verify roles (ADMIN vs INVESTIGATOR). Investigator tokens receive an immediate **403 Forbidden** on admin-only routes (e.g. POST /api/officers).
2. **Database Kernel (PostgreSQL Roles in roles-and-grants.sql):** Roles ifp_admin, ifp_investigator, and ifp_auditor possess differing SQL privileges. Investigators are granted SELECT, INSERT, UPDATE on entities but have **REVOKE DELETE** on cases, evidence, and audit logs to prevent evidence spoliation.

2. Server-Side & Database RBAC Verification Output (scripts/demonstrate_db_rbac.py)

```
=== SERVER-SIDE API RBAC ENFORCEMENT ===
[1] Authenticating as Field Investigator (CID-002)...
    -> Token Granted. Role: INVESTIGATOR
[2] Investigator reading directory (GET /api/officers)...
    -> Response: 200 OK (Permitted read-only access)
[3] Investigator attempting to provision officer (POST /api/officers)...
    -> Response: 403 FORBIDDEN
    -> Server Detail: "Access forbidden: Officer provisioning requires ADMIN clearance."
    -> [PASS] Server-side 403 Forbidden successfully enforced.

=== DATABASE-LEVEL PRIVILEGE MATRIX (roles-and-grants.sql) ===
ROLE: ifp_admin        -> ALL PRIVILEGES ON ALL TABLES IN SCHEMA public
ROLE: ifp_investigator -> SELECT ON officers; SELECT, INSERT ON case_activity, evidence_custody;
                          SELECT, INSERT, UPDATE ON cases, people, vehicles, devices, evidence;
                          REVOKE DELETE ON cases, evidence, evidence_custody, case_activity;
                          Attempting `DELETE FROM cases` -> SQL Error: 42501 (Permission Denied).
ROLE: ifp_auditor      -> SELECT ON ALL TABLES (Strict read-only viva inspection role).
```